Reporte de mejoras: Skill OWASP BALS para Kiro

Fecha	2026-11-10
Versión anterior	2.0.0 (2026-10-23)
Versión actual	2.2.0
Responsable	Byron Antonio Lainez Sasvin
Repositorio	https://github.com/Byronsasvin/owasp-bals-25

1. Resumen ejecutivo

La skill pasó de ser una guía de consulta a una herramienta de trabajo dentro de Kiro. Ahora revisa el código del proyecto abierto, propone parches, calcula severidad con CVSS 3.1 y 4.0 y guarda cada reporte en Markdown y PDF para el histórico.

Se corrigieron además errores que impedían o degradaban la carga en Kiro: formato de la skill no estándar, una carpeta documentada que no existía y afirmaciones sin respaldo.

Indicador	v2.0.0	v2.2.0
Formato de skill válido para Kiro	No	Sí
Carpeta `steering/`	Documentada, ausente	Presente
Ítems de checklist con contenido real	0 (solo el conteo)	72
Payloads/comandos de prueba	~15	26+ (no destructivos)
Revisión de código del workspace	No	Sí
Remediación con código	Lista corta	4 lenguajes y 10 vectores
Seguridad de APIs (REST, GraphQL, JWT)	No	Sí
CVSS	3.1	3.1 y 4.0
Reportes	Solo en chat	Archivo `.md` y `.pdf` con fecha
Casos de evaluación	0	10 con archivos de prueba
Validaciones automáticas (CI)	Solo avisos	Fallan ante errores

2. Problemas detectados y corregidos (v2.1.0)

#	Problema	Riesgo	Corrección
1	`name` de la skill con espacios y mayúsculas, y campos no estándar	Kiro podía no cargarla o activarla	`name` en minúsculas con guiones, igual que la carpeta; metadatos bajo `metadata`
2	Descripción sin criterio de activación	Activación poco fiable	Descripción con "cuándo usarla"
3	Carpeta `steering/` documentada y ausente	Incompatibilidad con el formato de Powers	`steering/owasp-security-testing.md` creado
4	Cifras sin respaldo (25+ payloads, 70+ ítems)	Pérdida de credibilidad	Contenido real en `references/`
5	IDs OWASP 2021 en un prompt de `POWER.md`	Respuestas incorrectas	IDs 2025
6	Integración AWS anunciada y no implementada	Expectativa falsa	Referencias eliminadas
7	Payload destructivo (`DROP TABLE`)	Daño en pruebas	Reemplazado por pruebas no destructivas
8	CI solo avisaba	Errores sin detectar	CI falla ante errores de formato o versiones

3. Mejoras agregadas (v2.2.0)

1. **Revisión de código del workspace** (`references/code-review.md`): patrones de riesgo por vector con CWE, cadena de suministro y búsqueda de secretos.
2. **Remediación con código** (`references/remediation.md`): antes y después en Python, Node.js, Java y C#.
3. **Hooks de Kiro de ejemplo** (`examples/hooks/`): revisión al guardar, revisión de dependencias y confirmación de autorización antes de escanear. Son opcionales.
4. **Casos de evaluación** (`evals/`): 10 pruebas con código vulnerable intencional para medir la skill.
5. **CVSS 4.0** (`references/cvss.md`) junto con 3.1.
6. **Seguridad de APIs** (`references/api-security.md`): OWASP API Top 10, GraphQL, JWT y OAuth.
7. **Perfiles de profundidad**: Rápido, Estándar y Completo.
8. **CWE y SARIF** (`references/reporting.md`): cada hallazgo con CWE y salida opcional para GitHub Code Scanning.
9. **Cumplimiento con advertencias**: el mapeo se declara orientativo, con proceso de validación contra los textos oficiales.
10. **Limpieza**: eliminadas tres plantillas duplicadas de la raíz; solo queda `templates/`.
11. **Idioma**: la skill responde en el idioma del usuario.
12. **Reportes en md y PDF** (`scripts/md-to-pdf.mjs`, `reports/`): histórico presentable a líderes, sin sobrescribir reportes anteriores.

4. Controles de seguridad de la propia skill

- Exige confirmar autorización y alcance antes de probar un objetivo.
- No ejecuta ataques contra producción ni terceros.
- Solo payloads no destructivos.
- No incluye secretos ni datos personales reales en reportes.
- No afirma cumplimiento normativo: habla de "posible brecha".

5. Limitaciones y pendientes

- La skill no se ha probado aún dentro de Kiro con los 10 casos de `evals/cases.md`. Es el siguiente paso.
- El mapeo de cumplimiento no se contrastó con los textos oficiales; está marcado como pendiente de validación.
- No se ejecutó el workflow de GitHub Actions; se validó el formato localmente.
- Las cifras de CVSS por categoría son de referencia, no sustituyen el cálculo por hallazgo.
- El PDF requiere Node.js y Chrome o Edge instalados en el equipo.
- El mapeo de CWE y de API Security Top 10 (edición 2023) debe revisarse al publicarse nuevas ediciones.

6. Próximos pasos propuestos

Paso	Responsable	Criterio de éxito
Ejecutar los 10 casos de `evals/cases.md` en Kiro	Autor	10 de 10 correctos
Validar el mapeo de cumplimiento con el responsable de cumplimiento	Cumplimiento	Mapeo aprobado
Reinstalar el Power actualizado en los equipos	Equipo	Versión 2.2.0 activa
Publicar la rama en GitHub y revisar el CI	Autor	CI en verde

7. Historial de versiones

Versión	Fecha	Cambio principal
1.0.0	2026-01	Versión inicial (OWASP 2021)
2.0.0	2026-10-23	OWASP Top 10:2025
2.1.0	2026-11-10	Compatibilidad con Kiro: skill, steering, references, CI
2.2.0	2026-11-10	Revisión de código, remediación, APIs, CVSS 4.0, reportes md y PDF